

P4 — DevOps, QA & Security Lead

RoadAssist Bharat · 76 days across 3 reviews Owns: cloud infrastructure · CI/CD · observability · all testing · security · SMS/IVR/USSD telecom gateway · deployment · compliance. Backs up **P2**.

Your three standing rules 1. The build is never broken on the main branch for more than 30 minutes. You own that number. 2. You are the only person who can say **"this is not ready to ship."** Use it. 3. Every alert has a runbook **before** it is switched on. An alert without a runbook trains people to ignore alerts.

REVIEW 1 — Foundation · Weeks 1–5 · 17 days

Week	Task	Days
1	Start TRAI DLT registration for SMS templates — do this before anything else. It is the longest lead item in the entire project and nobody can compress it. Register more templates than you think you need, with two vendors.	1
1	Cloud provider evaluation (data-localisation compliant); telecom gateway comparison; cost model	2
1–2	Compliance obligation register — DPDP Act 2023, TRAI, cloud empanelment, payment regulations — each mapped to the phase that satisfies it and the evidence that proves it	1
2	CI/CD skeleton: lint, typecheck, test, build, security scan on every pull request	2
2	Branch protection, CODEOWNERS, secret scanning, dependency automation	1
2	Test strategy document; environment strategy (local → preview → dev → staging → production)	1
3	STRIDE threat model with P1 across all 9 trust boundaries → a control list mapped to phases	4
3	SLO definitions with error budgets (Emergency gets 99.99%, everything else 99.9% or lower)	—
4	Database infrastructure, point-in-time recovery, nightly automated restore verification	2
5	Secrets management with rotation; SMS gateway with two vendors and automatic failover ; edge rate limiting; WAF	3

Deliverables

DLT registration submitted · compliance register · cost model · CI/CD pipeline · branch protections · test strategy · threat model · SLOs with error budgets · database infrastructure with verified backups · secrets management · dual SMS gateway.

Your Review 1 demo — 5 minutes

Open a pull request containing a lint error, a failing test **and a hardcoded password**. Watch CI block all three in under 8 minutes. Then delete a table in a scratch environment and restore it from point-in-time recovery to five minutes before the deletion. Finish by disabling the primary SMS vendor mid-login — the OTP still arrives via the secondary within the same latency budget.

Passed when

CI blocks lint, tests and secrets in under 8 minutes · every regulatory obligation is mapped to a phase and an evidence artefact · a backup is restored and verified automatically, nightly · SMS failover works, not just configured · every one of the top 10 threats has a named control and the phase it lands in.

A backup that has never been restored is not a backup. That is why the restore runs nightly from Review 1, not once at the end.

REVIEW 2 — Core Product · Weeks 6–12 · 27 days

Week	Task	Days
6–7	Observability stack — metrics, logs, distributed tracing, error reporting; auto-generated dashboard per service	4
7	<i>(within)</i> Log scrubbing at the library level — PII, tokens and payment data redacted automatically, verified by a test that logs a fake token	—

Week	Task	Days
7	Integration test infrastructure with real databases in containers; ephemeral preview environment per pull request	—
8	Mobile CI: signed Android + iOS builds distributed to the team on every merge, so everyone dogfoods continuously	3
9	ML infrastructure for P3; training on cheap interruptible compute; GPU scale-to-zero and budget alerts	3
10	Admin console + Fleet dashboard (taken off P2 to keep Review 2 achievable)	6
11–12	Telecom gateway — SMS command grammar, IVR menu tree in 8 languages, USSD session flow, vendor abstraction	6
12	Self-hosted map tile server and routing engine; offline map pack build pipeline	3
12	Network chaos harness for P2's offline testing; media upload pipeline with EXIF stripping and virus scanning	2

Deliverables

Observability stack · log scrubbing · preview environments · mobile CI with signed builds · ML infrastructure · admin + fleet portals · **telecom gateway (SMS, IVR, USSD)** · tile and routing infrastructure · chaos harness.

Your Review 2 demo — 7 minutes

Follow **one request** from the mobile app through the gateway, three services, the database and the AI gateway — as a single distributed trace. Show the log-scrubbing test catching a leaked token. Then the headline: on an actual **₹1,200 feature phone**, send **MADAD** by SMS, receive a reply, confirm location, get the mechanic's name and number, cancel. Then call the IVR number and do the same in Tamil. **No smartphone anywhere in that demo.**

SMS command grammar

Command	Also accepts	Effect
HELP	MADAD , SAHAYA , H	Start an assistance request
SOS	EMERGENCY , 112	Emergency — highest priority, immediate escalation
STATUS	S	Booking status and mechanic ETA
CANCEL	C	Cancel the active booking (confirms first)
LANG HI	any language code	Switch language for all future messages

Unrecognised input replies with the command list, never an error. A user who mistypes must not be stuck.

Passed when

One request produces one complete distributed trace · a fake token in a log is provably redacted · a feature-phone user can request help, track and cancel entirely over SMS · IVR works in all 8 languages with keypad input always available as a fallback · GPU pool scales to zero when idle.

REVIEW 3 — Complete System · Weeks 13–18 · 32 days

Week	Task	Days
13	Isolated emergency infrastructure — own node pool, own database pool, own SMS quota, spread across 3 zones	4
13	(within) The chaos test that matters most: scale every non-emergency service to zero, sever the main database — SOS must still reach a responder	—
14	Government mTLS: certificate issuance, renewal, revocation; tamper-evident audit log with hash chaining	3
14	ClickHouse cluster; change-data-capture infrastructure with replication-lag alerting and a kill switch	3
15–16	Load testing — 10k requests/sec steady, 50k spike, 100k concurrent tracking connections, 24-hour soak	4
15–16	Security testing — full OWASP checklist, dynamic + static analysis, dependency and container scanning, red-team pass	3
16	Chaos experiments — kill pods, partition the network, exhaust connections, expire certificates	3

Week	Task	Days
17–18	Production deployment — infrastructure as code, GitOps, canary releases with automatic rollback	8
17–18	(within) Disaster-recovery drill : restore into a clean region, measure recovery time and data loss against targets	—
17–18	(within) 25+ runbooks , one per alert; on-call handbook	—
18	Infrastructure right-sizing, autoscaling tuning, cost model per 100k users; compliance roadmap	4

Deliverables

Isolated emergency infrastructure with chaos proof · government mTLS and audit log · analytics infrastructure · load, security and chaos test reports · production infrastructure as code · disaster-recovery plan **with a passed drill** · 25+ runbooks · cost model · go/no-go recommendation.

Your Review 3 demo — 8 minutes

Scale the **entire platform to zero replicas**, live, in front of the panel. Trigger an SOS from a phone. It still works. Then deploy a change through the full pipeline to production with one approval click; deliberately break the canary and watch it roll back automatically. Then run the disaster-recovery drill: restore the platform into a clean region, timed, live. Finish by presenting the load and security reports — **including what failed and what you did about it**.

Passed when

Emergency survives with every other service down · 95th percentile under 300 ms at 10,000 requests/sec · graceful degradation at 50k spike, not collapse · zero high or critical security findings survive · rollback of any service under 5 minutes, proven by drill · recovery time under 4 hours, data loss under 5 minutes, **proven not asserted** · a person who did not write a runbook can resolve a simulated incident using only that runbook.

Chaos experiments (each must end in documented degraded behaviour, never an outage)

Experiment	Expected
Kill 1 of 3 API pods	No user-visible impact
Kill all AI pods	Rules fallback serves everything; no errors reach users
Kill the primary database	Failover under 60 seconds; in-flight requests fail cleanly
Exhaust the connection pool	Requests queue then shed with a retry hint; no crash
Scale everything except Emergency to zero	SOS still works via the degraded path
Primary SMS vendor total outage	Automatic failover, no user impact
Clock skew of 5 minutes on one node	Token validation still correct within tolerance

Your Key Design Decisions (defend these to the panel)

Decision	Why
DLT registration started in Week 1	It is the longest lead item in the project and blocks all authentication. Everything else can be parallelised; this cannot.
Two SMS vendors from day one	The SMS gateway is a single point of failure for all authentication. One vendor is not a design.
Emergency gets its own failure domain	Life safety needs a different reliability class: separate deploy, separate quota, and a degraded path sharing zero dependencies with the platform.
Deliberately boring infrastructure	Managed services, one cluster per environment, no service mesh. A four-person team must be able to operate this at 3 a.m.
Self-hosted maps	Commercial per-tile licensing at national scale is prohibitive. Tiles become a compute cost, not a licence fee.

Decision	Why
Log scrubbing in the library, not by convention	Conventions fail under deadline pressure. Automatic redaction does not.
Error budget policy is automatic	Burn 50% of a service's budget and feature work on it stops. It is a rule, not a discussion.